

TrustAI

AI Governance Playbook

A framework for organizations that take responsibility seriously.

Version 1.0 2026 trustai.com.tr

*Editor: Prof. Dr. Süreyya Akyüz
Authors: Dilara Karaduman-Nisa Yegin*

FOREWORD

Trustworthy AI is not an aspiration. It is an engineering and governance problem — one that requires both rigor and honesty about what we do not yet know.

Most AI governance writing is thorough and largely ignored. We wanted to write something different.

Principles matter. But they only matter when someone in an organization knows which ones apply to their system, when to invoke them, and what to actually do. That gap between principle and practice is where most governance efforts quietly fail. It is also where TrustAI spends most of its time.

Some of what follows will feel incomplete. The field is still settling, and we would rather be honest about that than pretend otherwise. Use what is useful, revise what does not fit, and come back to the rest when it becomes relevant.

Prof. Dr. Süreyya Akyüz

Founder & CEO, TrustAI

HOW TO READ THIS PLAYBOOK

This document is not meant to be read cover to cover in a single sitting. It is structured so that different readers can find different things. A compliance officer preparing for EU AI Act obligations will use Chapters 3 and 6 most heavily. A technical team embedding explainability into a production system will spend most of their time in Chapter 5. An executive trying to understand what governance actually requires will find the clearest picture in Chapters 1 and 2.

Each chapter opens with the question it is trying to answer. If the answer to that question is not something your organization currently needs, skip it. Come back when it is.

01

The Case for Governance

Why this is not optional, and why most organizations are further behind than they think.

Most organizations treat AI governance as a compliance problem. A regulation is coming, and they need to be ready for it. This is a reasonable starting point, but it is not a strong foundation. Governance built around deadlines tends to stop at the minimum required. The stronger case is more straightforward. AI systems make decisions, or support decisions, that affect real people. When those systems fail responsibility does not disappear. Governance is how an organization determines, before something goes wrong, who is accountable, what will be done about it, and how the failure will be detected in the first place. Good intentions are not a governance substitute. Systems built carefully can still inherit bias from the data they were trained on, the proxies they rely on, or the contexts they were not designed for.

Every AI system is a commitment. Governance is what makes that commitment legible.

THE REGULATORY MOMENT

The EU AI Act entered into force in August 2024. Prohibited practice provisions applied from February 2025 and obligations for high-risk AI systems take full effect in August 2026. For organizations operating in or serving European markets, it sets binding requirements on how AI systems are designed, deployed, and documented.

Other frameworks matter too. ISO/IEC 42001, published in 2023, establishes an AI management system standard along lines similar to ISO 27001 for information security. The NIST AI Risk Management Framework, though voluntary in the United States, functions as a widely used reference point. In Turkey, the National AI Strategy 2021–2025 is laying the groundwork for sector-specific guidance that will increasingly align with European approaches.

Treating these as separate compliance exercises leads to duplicated effort. The underlying logic is consistent across all of them: AI systems require structured, documented, and auditable governance. Work on one framework tends to advance work on the others.

THE RISK OF WAITING

The most common governance failure is not bad intentions. It is delay. Organizations wait until a system is in production before asking who owns it. They wait until a complaint before auditing for bias. They wait until a regulator asks before preparing documentation. By then, retroactive governance costs significantly more than building it in from the start and the harm may already have occurred.

This playbook operates on a different premise: governance decisions made early are cheaper, more effective, and less disruptive than decisions made under pressure. The

cost of waiting is not only financial. When biased systems reach production, harms are often irreversible. The COMPAS recidivism tool assigned disproportionately high risk scores to Black defendants affecting real sentencing outcomes before the disparity was documented. A widely deployed healthcare algorithm systematically underestimated Black patients' needs because it used cost as a proxy for medical need a proxy that reflected unequal access, not unequal health. Retroactive correction did not undo the harm already done.

For organizations in Turkey, the National AI Strategy 2021–2025 is establishing regulatory groundwork that will increasingly align with European approaches. Those who build governance infrastructure now will be better positioned when these requirements crystallize.

02

Transparency in AI Governance

What transparency actually requires, and how to build it in.

Transparency is not a feature you add to an AI system. It is a property of how an organization relates to the systems it builds and deploys and to the people those systems affect. An organization that cannot explain what its AI systems do, why they produce the outputs they do, or who is responsible when something goes wrong is not a transparent organization, regardless of what its documentation says.

In regulatory terms, transparency has a specific meaning. The EU AI Act requires that certain systems disclose their AI nature, that high-risk systems maintain logs sufficient for post-hoc review, and that documentation be kept current and accessible to oversight bodies. These are minimum requirements. Meeting them is necessary but not sufficient.

The more demanding version of transparency asks three questions. What does this system do, and do the people it affects know that? Can the decisions it produces be explained in terms that are meaningful to those affected? And when something goes wrong, is there a clear record of what happened and who was responsible?

These questions do not have purely technical answers. They require organizational commitments to documentation, to oversight, to explanation, and to accountability. TrustAI's SAFE Framework is structured around exactly these commitments. Safety, Accountability, Fairness, and Explainability are not four separate concerns. They are four dimensions of what it means for an organization to be genuinely transparent about its use of AI. They are sequenced deliberately. Safety without accountability produces systems where failures are identified but owned by no one. Accountability without fairness produces systems where ownership is clear but harm is

systematically distributed. Fairness without explainability produces systems where equitable outcomes cannot be verified or challenged. And explainability without the other three produces documentation that serves no one.

SAFE is not a framework you implement. It is a framework you inhabit — a set of questions you keep asking.

SAFETY

Safety governance begins before a system is deployed and does not end when it is. In practice, this means conducting structured risk assessments at the design stage not to achieve a passing score, but to surface and document assumptions about how the system might behave in conditions not anticipated by its developers. It means building monitoring infrastructure that can detect behavioral drift in production. It means having incident response protocols that define not just how to respond to a failure, but who has the authority to take a system offline.

For high-risk AI systems, safety governance also means adversarial testing. Red-teaming, stress testing under edge conditions, and deliberate attempts to produce harmful outputs are not paranoia they are standard practice for any system whose failures have serious consequences.

ACCOUNTABILITY

Every AI system in an organization should have a named owner. Not a team, not a department a person. That person is responsible for the system's behavior, for keeping its documentation current, for ensuring that monitoring is in place, and for escalating when something goes wrong. This sounds simple and is surprisingly rare.

Accountability also requires audit trails. An organization that cannot reconstruct why a model produced a particular output on a particular date has no meaningful accountability for that output. Logging requirements, model versioning, and decision records are not bureaucracy they are the infrastructure of accountability

FAIRNESS

Fairness in AI systems is not a binary property. A system can be fair in one sense and unfair in another, fair on aggregate and unfair to specific groups, fair today and unfair after distribution shift. This means that fairness governance requires choices: which metrics matter for this system, in this context, for these affected groups. In practice, these choices are made using group fairness metrics. Statistical parity focuses on equal outcome distribution across groups, equal opportunity ensures equal true positive rates among those who truly deserve a positive outcome, equalized odds requires both equal true and false positive rates, and predictive parity requires predictions to be equally reliable across groups. These metrics are often mutually incompatible, so selecting one reflects ethical and contextual priorities. Organizations must therefore explicitly choose and document which metric they prioritize and justify it based on context and potential harms.

Bias auditing should occur at three stages: at data collection and curation, at model training and validation, and at deployment. Each stage can introduce or amplify bias in ways that are not visible at the others. An organization that only audits at one stage is auditing a subset of its fairness risk.

EXPLAINABILITY

The question explainability is trying to answer is not 'how does this model work?' It is 'can the people affected by this system's decisions understand why those decisions were made, and challenge them if they are wrong?' These are different questions and they require different answers for different audiences.

A technical team needs feature importance scores, confidence distributions, and data provenance information. A business stakeholder needs a risk-calibrated summary in terms they can act on. An individual whose loan application was rejected, or whose medical triage was deprioritized, needs a plain-language explanation and a clear path to recourse. Explainability that serves only one of these audiences is partial at best.

03

EU AI Act Compliance

What the regulation actually requires, and what it means for how you build and deploy AI.

The EU AI Act is a risk-based regulation. Its obligations scale with the potential harm a system can cause. Understanding compliance begins with understanding where your systems sit in the risk taxonomy and being honest about that classification rather than motivated to minimize it.

THE RISK TAXONOMY

At the top are prohibited systems: AI applications the regulation treats as categorically unacceptable. Social scoring by public authorities. Real-time biometric surveillance in public spaces without narrow, court-authorized exceptions. AI systems that exploit specific vulnerabilities to influence behavior. These are not edge cases for most commercial organizations, but the category matters because it defines the logic of the framework some applications of AI are simply off the table.

High-risk systems are the regulation's core. These are AI systems deployed in contexts where errors have serious consequences: critical infrastructure, employment and worker management, essential private and public services, education, law enforcement, border control, administration of justice. For these systems, the Act requires a risk management system, comprehensive technical documentation, automatic logging, human oversight measures, and a conformity assessment before deployment. These are not light obligations.

Below high-risk, the regulation creates limited-risk obligations focused on transparency. Chatbots must disclose that users are talking to an AI. Deepfakes must be labeled. These are minimal requirements, but they signal a broader principle: people interacting with AI systems have a right to know it.

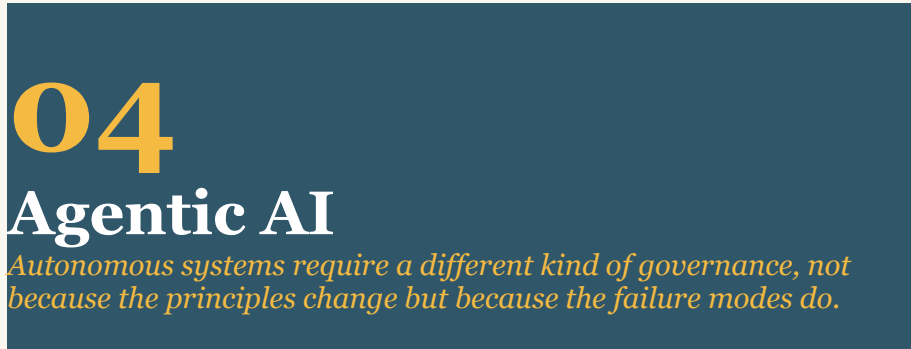
PROVIDER VERSUS DEPLOYER

One of the most practically important distinctions in the Act is between providers organizations that develop AI systems and place them on the market and deployers, who use AI systems in their own operations. The obligation structure differs significantly. Providers carry the primary technical and documentation burden. Deployers are responsible for implementing human oversight measures, conducting fundamental rights impact assessments in certain contexts, and reporting incidents. An organization can be both simultaneously, which is common and requires careful disentangling of which obligations attach to which role. Turkish organizations that both develop AI systems and deploy them in their own operations are simultaneously subject to provider and deployer obligations. This dual-role scenario is common and requires explicit internal mapping: which compliance obligations attach to the development function, and which to the deployment function. Failure to disentangle these roles is one of the more common compliance errors in organizations new to structured AI governance.

THE COMPLIANCE TIMELINE

February 2025 marked the first major deadline: prohibited practice provisions became applicable. August 2025 brings obligations for general-purpose AI models and organizational governance and literacy requirements. August 2026 is the most significant date for most organizations when high-risk AI obligations become fully enforceable. August 2027 covers high-risk AI embedded in regulated products under existing EU law.

Organizations that have not yet begun a systematic review of their AI systems against the Act's risk taxonomy are behind. Not critically so, but the gap between current state and full compliance for high-risk systems is typically 12 to 18 months of sustained work. That window is narrowing.



Agentic AI systems those capable of planning and executing multi-step actions using tools, APIs, and external services are qualitatively different from predictive or generative models that produce outputs in response to single inputs. The governance challenge is not harder in principle but different in structure.

The core difference is that agentic systems can take actions with real-world consequences, often at a speed and scale that outpaces human review. A model that classifies documents incorrectly produces a wrong answer. An agent that misinterprets a goal specification can delete files, send communications, make purchases, or initiate processes that are difficult or impossible to reverse. The reversibility of actions not just their correctness becomes a governance variable.

The question for agentic governance is not 'what did the system decide?' but 'what did it do, and can we undo it?'

WHERE GOVERNANCE NEEDS TO CHANGE

Three governance adaptations matter most for agentic systems. The first is scope definition. An agent's authorized action space—what it is permitted to do, what systems it can access, what it cannot do under any circumstances—must be specified explicitly and enforced technically, not just stated in documentation. Soft constraints are insufficient for systems that can act autonomously.

The second is logging architecture. Agentic systems produce chains of actions, not single outputs. Audit trails need to capture the full sequence of steps, the reasoning at each decision point where that is extractable, and the state of the world at the time each action was taken. A log that records only the final output of an agentic task is not a meaningful audit trail.

The third is human oversight calibration. The appropriate level of human involvement depends on the risk level of the actions the agent can take and the reversibility of those actions. For actions that are irreversible or that have significant external consequences, human approval before execution is the only defensible position. For lower-stakes, reversible actions, monitoring with intervention capability may be sufficient. These thresholds need to be set explicitly, not left to the judgment of whoever is running the system on a given day.

FAIRNESS IN AGENTIC SYSTEMS

Agentic systems introduce a specific fairness risk that predictive models do not: feedback amplification at scale and speed. When an agent acts on biased data or a biased objective, it does not produce a single biased output—it executes a sequence of actions that can entrench or worsen disparities before any human reviewer is aware. Feedback loop dynamics identified in static systems are significantly more severe in agentic contexts because the agent is both consuming and generating data that shapes its future behavior. Governance of agentic systems must therefore include explicit fairness monitoring across the full action sequence, not only at final outputs, and must specify in advance which demographic or population-level metrics will be tracked.

MULTI-AGENT SYSTEMS

When multiple agents interact—one agent delegating tasks to another, or several agents coordinating toward a shared goal—accountability becomes diffuse in ways that require deliberate structural attention. Each agent in a system should have a defined scope of authority. When an agent receives an instruction from another agent, it is not released from its own constraints by virtue of the instruction's source. Governance failures in multi-agent systems often trace to the assumption that an instruction from a trusted source is a sufficient authorization. It is not.

05

Explainability in Practice

The gap between what XAI tools produce and what stakeholders actually need.

There is a significant and underappreciated gap between the technical literature on explainability and what organizations need to do in practice. The literature tends to focus on method correctness whether a SHAP value accurately represents the contribution of a feature to a model's output. Practice requires something more: explanations that are useful to specific people in specific contexts, that can be interrogated, and that support the kind of meaningful oversight that governance requires.

This chapter is about bridging that gap.

THE TOOLS

SHAP (SHapley Additive exPlanations) is the most widely used technique for explaining individual model predictions in tabular settings. It assigns each input feature a score representing its contribution to a specific prediction, drawing on game-theoretic foundations that give the approach strong theoretical properties. LIME (Local Interpretable Model-agnostic Explanations) takes a different approach fitting a simple interpretable model to the neighborhood of a specific prediction that works across model architectures but makes weaker guarantees about faithfulness to the underlying model. For neural networks processing text or images, gradient-based methods including Integrated Gradients and attention visualization provide attribution maps that can identify which parts of an input most influenced an output.

Counterfactual explanations are often underused but highly practical for decision-support contexts. Rather than explaining why a model produced a particular output, they answer the question: what would have needed to be different for the output to change? For an individual affected by an AI-assisted decision, this is often more actionable than feature importance scores.

From a legal and fairness perspective, counterfactual explanations are particularly significant. They provide individuals with actionable information about what would need to change for a different outcome to occur. This supports the ability to contest algorithmic decisions and aligns with data protection frameworks such as the GDPR, which emphasize meaningful information about automated decision-making. For high-impact decisions, they should be considered a core component of explanation systems rather than an optional add-on.

THE AUDIENCES

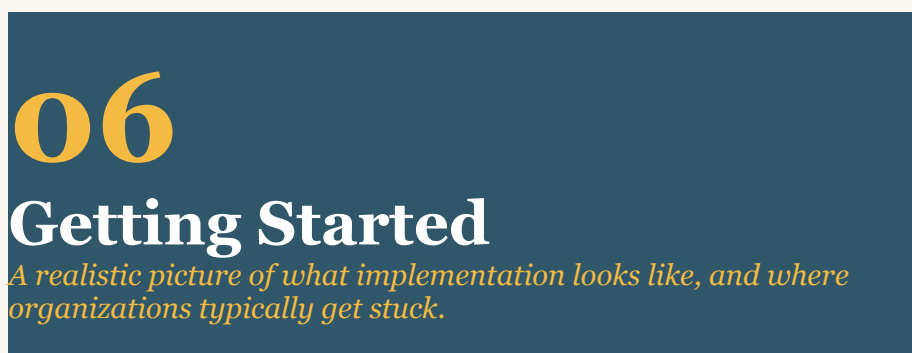
Each of these tools produces outputs that are meaningful to technical users and largely opaque to everyone else. Governance requires that explanations be calibrated to audience. A technical team validating model behavior needs feature importance scores, confidence distributions, and information about the training data distribution. A business stakeholder approving a high-risk deployment needs a risk

summary in terms that connect to business outcomes. An individual affected by a decision needs an explanation in plain language that tells them what mattered, what they could change, and how they can challenge the decision.

These are not simplifications of each other. They are genuinely different explanations, produced from the same underlying technical outputs but shaped for different purposes. Building the translation layer between technical XAI outputs and stakeholder-appropriate explanations is one of the underinvested areas of explainability practice.

EXPLAINABILITY BY DESIGN

The most important thing to know about explainability is that retrofitting it is hard. Models trained without explainability requirements, on data that was not curated with explainability in mind, for applications where explanation format was not specified, tend to produce explanations that are technically valid and practically useless. Building explainability in from the design stage specifying what kinds of explanations will be required, for which audiences, in which contexts, before selecting a model architecture consistently produces better outcomes.



WHERE ARE YOU NOW?

Before working through this playbook, it helps to know where you are starting from. These questions are not a test they are a way of locating yourself honestly before deciding where to focus.

	Yes	Partial	No
You know what AI systems your organization is currently running			
Each system has a single person who is accountable for it			
You can explain why a specific model made a specific decision last month			
You have a process for catching problems in deployed systems before someone else does			
You have audited any of your AI systems for bias in the past year			

You know where your systems sit under the EU AI Act			
Any of your AI systems can be stopped immediately if something goes wrong			
The people your systems affect have a way to understand or challenge decisions made about them			

Mostly yes: You are at level three or above. Use this playbook to identify and close specific gaps.

About half: You are at level two. Chapters 2, 3, and 6 are your starting point.

Mostly no: You are at level one. Start with Chapter 6, Phase One, and work forward.

Governance implementation fails in predictable ways. The most common is the policy-without-practice failure: an organization produces governance documentation that is technically comprehensive and operationally inert. Nobody consults it when making actual decisions because it was not designed to inform actual decisions. The second most common is the pilot-without-scale failure: a rigorous governance process is applied to one system and not extended to others, leaving the organization with an impressive case study and unmitigated risk in the rest of its portfolio.

The framework below is designed to avoid both.

Start with inventory. You cannot govern systems you do not know you have.

PHASE ONE: ASSESS

The starting point is a complete inventory of AI systems in use or development. This includes systems built internally, systems procured from vendors, and systems embedded in other software products. The inventory should capture, at minimum: what each system does, what data it uses, what decisions it influences, who owns it, and where it sits in the EU AI Act risk taxonomy. The inventory exercise should also include a structured bias source assessment for each system identified. This means documenting: what historical patterns may be encoded in the system's training data; whether the populations the system affects are adequately represented in that data; what proxy variables are in use and whether they carry different meanings across demographic groups; and how the system's outputs feed back into future data or decisions. This assessment does not need to be exhaustive at the inventory stage its purpose is to surface which systems carry the highest fairness risk and should be prioritized for deeper audit. For most organizations, this exercise surfaces AI use that governance and compliance functions did not know existed.

Once the inventory exists, the next step is an honest gap analysis against the SAFE dimensions and applicable regulatory requirements. The goal is not a clean scorecard. It is a prioritized list of the governance deficits that carry the most risk.

PHASE TWO: GOVERN

Phase two is where most of the structural work happens. It involves establishing governance policy, assigning owners to systems that do not have them, implementing

documentation requirements, deploying monitoring infrastructure, and beginning the conformity assessment process for any high-risk systems. For organizations with large AI portfolios, this phase will inevitably require prioritization not everything can be addressed at once, and that is appropriate. The prioritization criteria should be transparent and documented.

PHASE THREE: MONITOR

Governance that does not include continuous monitoring is governance in name only. Production AI systems drift. Data distributions shift. Use cases expand beyond what was originally anticipated. New regulatory requirements emerge. The monitoring phase is not a phase that ends it is the steady state that governance is designed to reach.

MATURITY, HONESTLY DESCRIBED

Level one organizations have no formal governance. They respond to incidents after the fact and have no documentation of AI system behavior or ownership. Level two organizations have begun the work: some documentation exists, there is governance awareness, but it is inconsistent and not yet operationalized. Level three organizations have structured governance in place ownership is assigned, risk assessments are conducted, monitoring exists for the highest-risk systems. Level four organizations are managing governance quantitatively: metrics are tracked, audit trails are complete, EU AI Act compliance is in place. Level five organizations are optimizing: governance is embedded in culture, not just process, and the organization is contributing to the development of standards and best practices rather than simply meeting them.

Most organizations reading this playbook are at level one or two. That is not a criticism. It is the starting point.

Level	Existing Definition	Fairness Extension
1	No formal governance	No fairness assessment; issues are handled reactively, typically only after complaints or incidents
2	Awareness emerging but inconsistent	Some performance disparities across groups are monitored, but not systematically or consistently across systems
3	Structured governance in place	Bias audits are integrated into training, validation, and deployment processes; fairness metrics are selected and justified for key systems
4	Quantitative management	Multi-dimensional fairness metrics are actively monitored; intersectional analysis is performed; trade-offs between accuracy and fairness are explicitly documented

5	Optimization	Fairness is embedded into organizational culture; continuous improvement loops exist; the organization contributes to standards, best practices, or regulatory discussions on fairness
---	--------------	--

07

Türkçe Özet

Bu playbook'un tüm içeriğinin özeti ve Türkiye bağlamı.

Yapay zeka yönetiřimi, son yıllarda teknik bir niř olmaktan çıkıp kurumsal sorumluluk gündeminin merkezine yerleşmiştir. Bunun nedeni oldukça açıktır: Yapay Zeka sistemleri artık milyonlarca insanı etkileyen kararlar vermekte veya bu karar süreçlerine doğrudan katkıda bulunmaktadır. Sağlık, finans, kamu hizmetleri, işe alım, eğitim gibi alanlarda kullanılan bu sistemlerin hata yapması durumunda sorumluluğun açık bir şekilde tanımlanması gerekmektedir.Yönetişim ise bu sorumluluğun kim tarafından ve nasıl üstlenileceğini önceden belirleyen mekanizma olarak öne çıkmaktadır.

SAFE ÇERÇEVESİ

TrustAI'nın SAFE Çerçevesi dört temel boyutu kapsamaktadır: Güvenlik (Safety), Hesap Verebilirlik (Accountability), Adalet (Fairness) ve Açıklanabilirlik (Explainability). Bu dört boyut birbirinden bağımsız değildir ; aksine,her biri diğerinin ön koşulunu oluşturmaktadır.Sahipliği ve sorumluluğu tanımlanmamış bir sistemde güvenlik protokollerinin etkin şekilde işlemesi mümkün değildir. Benzer şekilde, açıklanabilir olmayan bir sistemde adalet iddiası yeterli temele dayanmaz. Çerçevenin temel değeri, her boyutun ayrı ayrı ele alınmasını ve değerlendirilmesini zorunlu kılmasında yatmaktadır.

AB YAPAY ZEKA YASASI

AB Yapay Zeka Yasası Ağustos 2024 tarihinde yürürlüğe girmiştir.Yasa,risk bazlı bir çerçeve sunmakta; yasaklı uygulamaları tanımlamakta , yüksek riskli sistemler için kapsamlı uyum yükümlülükleri getirmekte , ve daha düşük riskli sistemler için şeffaflık zorunlulukları öngörmektedir. Yüksek riskli sistemlere ilişkin tam kapsamlı yükümlülüklerin ise Ağustos 2026 itibarıyla yürürlüğe girmesi planlanmaktadır. . AB pazarında faaliyet gösteren veya AB merkezli kuruluşlara hizmet veren Türk şirketleri de bu yükümlülüklerden muaf değildir.

AJANLI YZm

Otonom, çok adımlı eylem gerçekleştirebilen Yapay Zeka sistemleri 'ajanlar' geleneksel yönetim çerçevelerinin yeterince ele almadığı çeşitli riskler barındırmaktadır.Buradaki temel sorular şunlardır:Bu sistem hangi eylemleri gerçekleştirebilir,gerçekleştirilen eylemler geri alınabilir mi, ve herhangi bir sorun

durumunda kim müdahale edebilir? Bu sorulara açık ve net yanıtlar verilmeden ajan tabanlı bir sistemin devreye alınması, kontrol edilmesi güç bir sürecin başlatılması anlamına gelmektedir.

TÜRKİYE BAĞLAM

Türkiye 2021-2025 Ulusal Yapay Zeka Stratejisi çerçevesinde sektöre özgü düzenleyici rehberlik mekanizmaları geliştirmektedir. AB ile olan ekonomik ve hukuki ilişkiler göz önünde bulundurulduğunda , Türk kuruluşlarının AB Yapay Zeka Yasası uyumluluğunu stratejik bir öncelik olarak ele alması kaçınılmaz hale gelmektedir.. TrustAI ise bu süreçte araştırma, danışmanlık ve ...?? standart geliştirme çalışmaları aracılığıyla kurumsal kapasite oluşturmayı desteklemektedir.

Dilara:



Agentic AI: AI systems capable of planning and executing multi-step actions autonomously, using tools, APIs, and external services. Unlike models that produce a single output in response to a single input, agentic systems take sequences of actions with real-world consequences many of which cannot be undone.

Audit trail: A complete, time-stamped record of a system's decisions and actions, sufficient to reconstruct what happened, why, and who was responsible. A meaningful audit trail captures inputs, outputs, and the reasoning behind decisions not just final results.

Bias auditing: A structured process for identifying whether an AI system produces systematically different outcomes for different groups of people. Bias auditing should occur at data collection, model training, and deployment stages each can introduce or amplify bias in ways the others cannot detect.

Conformity assessment: The process by which a high-risk AI system is evaluated against the requirements of the EU AI Act before deployment. Depending on the system, this may be conducted internally or by a third-party notified body.

Counterfactual explanation: An explanation that answers the question: what would have needed to be different for this decision to have gone the other way? Counterfactuals are often more useful to affected individuals than feature importance scores because they indicate what is actionable.

Deployer: Under the EU AI Act, an organization that uses an AI system developed by another party in its own operations. Deployers have distinct compliance obligations from providers, including human oversight measures and incident reporting.

Distribution shift / Drift: A change in the statistical properties of the data a deployed model encounters in production, compared to the data it was trained on. Drift can degrade model performance and introduce new bias without any change to the model itself.

Explainability: The capacity of an AI system to produce outputs that can be understood and interrogated by the people who use or are affected by it. Explainability requires different types of explanation for different audiences technical, organizational, and individual.

Fairness metrics: Quantitative measures used to assess whether an AI system produces equitable outcomes across different groups. Common metrics include statistical parity, equal opportunity, equalized odds, and predictive parity. These metrics are often mutually incompatible; choosing one requires explicit justification.

High-risk AI: A category defined by the EU AI Act for AI systems deployed in contexts where errors have serious consequences, including critical infrastructure, employment, essential services, education, law enforcement, and the administration of justice. High-risk systems are subject to the most demanding compliance obligations under the Act.

Human-in-the-loop: A governance design in which a human is required to review or approve certain decisions or actions before they are executed. The appropriate level of human involvement depends on the risk and reversibility of the actions involved.

Incident response: A predefined process for detecting, escalating, and addressing failures in AI systems. An effective incident response protocol specifies not just what to do when something goes wrong, but who has the authority to act and what constitutes a reportable event.

LIME Local Interpretable Model-agnostic Explanations: A technique that explains individual model predictions by fitting a simpler, interpretable model to the behavior of the original model around a specific input. Works across model architectures but makes weaker faithfulness guarantees than SHAP.

Model card: A structured document that describes an AI system's intended use, performance characteristics, known limitations, and fairness properties. Model cards are a standard governance artifact for documenting what a system does and does not do.

Provider: Under the EU AI Act, an organization that develops an AI system and places it on the market or puts it into service. Providers carry the primary technical and documentation burden under the Act.

Red-teaming: A structured adversarial testing process in which a system is deliberately subjected to edge cases, hostile inputs, and attempts to produce harmful outputs. Standard practice for any system whose failures have serious consequences.

SHAP: SHapley Additive exPlanations. A technique for explaining individual model predictions by assigning each input feature a score representing its contribution to a specific output. Draws on game-theoretic foundations and is the most widely used explainability method for tabular data.